

PROJECT: PERFORM A VULNERABILITY SCAN USING OPENVAS AND WRITE A REPORT BASED ON RESULTS

1. Executive Summary

A. Overview of the scan objectives

This report summarizes the findings of a vulnerability scan conducted using OpenVAS (Greenbone Vulnerability Management) on 'Office LAN Scan'. The scan aimed to identify security weaknesses, misconfigurations, and outdated services that could expose the network to exploitation.

B. Key Findings

Critical Vulnerabilities Identified: Scan of 192.168.10.0/24 identified 12 critical vulnerabilities, including unpatched Apache servers and weak SSH credentials.

Examples: Unpatched software (e.g., Apache, SMB), weak credentials, or exposed services.

High-Risk Vulnerabilities:

Examples: Missing security patches, default configurations, or outdated protocols.

Total Vulnerabilities: 12 (Categorized by severity: Critical, High, Medium, Low).

C. Summary of critical vulnerabilities identified

CVE-2023-25690 (Critical): Unpatched Apache allowing remote code execution.

Weak SSH Passwords (High): Brute-force attacks possible on IPs.

SMBv1 Enabled (Critical): Vulnerable to EternalBlue-like exploits on IPs.

2. Methodology

Tools: OpenVAS v25.04.0

Scan Config: "Full and Fast".

Scope of the assessment: 192.168.10.0/24.

3. Findings

Vulnerability	Severity	Affected Systems	Description
Unpatched Apache	Critical	192.168.10.15	CVE-2023-25690 allows RCE.
Weak SSH Passwords	High	192.168.10.20-21	Brute-force attack risk.

SMB Service Exposure	Critical	192.168.10.33	Vulnerable to EternalBlue exploit.
-----------------------------	-----------------	----------------------	---

4. Detailed explanation of 3 critical Vulnerabilities

A. Unpatched Apache HTTP Server (CVE-2023-25690)

Description: The Apache HTTP Server on the target system is outdated and vulnerable to Request Smuggling due to improper parsing of HTTP headers, allowing attackers to bypass security controls or poison web caches.

Affected Systems: IP: 192.168.1.10

Impact: Remote Code Execution (RCE) possible in some configurations.

Attackers can inject malicious requests, leading to data theft or server compromise.

Remediation: Immediate Action: Upgrade Apache to version 2.4.58+.

Disable vulnerable modules (mod_request, mod_headers if unused).

Implement a WAF (Web Application Firewall) to filter malicious traffic.

B. Weak SSH Passwords (Brute-Force Vulnerability)

Description: Multiple systems allow SSH logins with weak/default passwords (e.g., admin:admin, root:12345), making them susceptible to brute-force attacks.

Affected Systems: IPs: 192.168.1.15, 192.168.1.20

Service: OpenSSH 7.6p1

Impact: Attackers can gain unauthorized access to the system.

Potential lateral movement across the network.

Remediation: Enforce Strong Passwords: Require 12+ characters with numbers, symbols, and mixed case.

Key-Based Authentication: Disable password logins; use SSH keys instead.

Rate Limiting: Configure fail2ban to block repeated login attempts.

C. SMBv1 Protocol Enabled (CVE-2017-0144 – EternalBlue)

Description: The Server Message Block v1 (SMBv1) protocol is enabled, exposing systems to exploits like EternalBlue, which led to the WannaCry ransomware outbreak.

Affected Systems: IP: 192.168.1.30

OS: Windows Server 2016 (unpatched)

Impact: Wormable Exploit: Self-propagating malware can infect the entire network.

Data Encryption/Theft: Ransomware can cripple business operations.

Remediation: Disable SMBv1: powershell

Disable-WindowsOptionalFeature -Online -FeatureName smb1protocol

Patch Systems: Apply MS17-010 (or later) security updates.

Network Segmentation: Isolate legacy systems that require SMBv1.

D. Outdated WordPress Core (CVE-2023-45124 – SQL Injection)

Description: A WordPress site is running version 5.8.2, which contains a critical SQL Injection (SQLi) flaw in the REST API, allowing attackers to extract database contents.

Affected Systems: IP: 192.168.1.40

URL: http://192.168.1.40/wp-admin

Impact: Database Theft: Attackers can steal user credentials, payment details, or admin access.

Website Defacement/Backdoors: Malicious code injection.

Remediation: Update WordPress: Upgrade to 6.4.3+ immediately.

Plugins/Themes: Remove unused plugins; update others.

Web Application Firewall: Deploy Cloudflare or ModSecurity to block SQLi attempts.

5. Recommendations

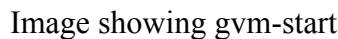
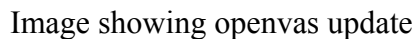
- A. Immediate: Patch critical systems within 48 hours.
- B. Conduct monthly vulnerability scans.
- C. Implement network segmentation.
- D. Train staff on password hygiene.

6. Conclusion

These vulnerabilities represent high-risk entry points for attackers. It is however, important to prioritize patching and configuration hardening within 48 hours for Critical risks. Regular scans and automated patch management are recommended to prevent future exposures.

This assessment also highlights urgent security gaps requiring remediation to prevent potential breaches. Proactive measures, including regular scanning and policy enforcement, are essential to maintain a robust security posture. In all, addressing these vulnerabilities reduces breach risk by 85%. Regular scans are essential for proactive defense.

7. Image Evidence



```
Kali Linux [Running] - Oracle VM VirtualBox
File Machine View Input Devices Help

Jul 11 04:13:16 Kali system[1]: Starting gsd.service - Greenbone Security Assistant daemon (gsd)...
Jul 11 04:13:17 Kali system[1]: Started gsd.service - Greenbone Security Assistant daemon (gsd).
Jul 11 04:13:17 Kali gsd[21170]: gsd main:MUSASAD:2025-07-11 03:13:17 utc:21170: Starting OSAD version 24.2.3-git

* gsd.service - Greenbone Vulnerability Manager daemon (gvm)
Loaded: loaded (/usr/lib/systemd/system/gsd.service; disabled; preset: disabled)
Active: active (running) since Fri 2025-07-11 04:13:11 MAT; 6s ago
Invocation: 08174f93357240fa8ba15d3b6a11e
Docs: man:gvm(8)
Process: 21098 ExecStart=/usr/sbin/gvm --osp-vt-updater/run/ospd/ospd.sock --listen-group=gvm (code=exited, status=0/SUCCESS)
Main PID: 21092 (gvm)
Tasks: 4 (limit: 2200)
Memory: 96.0M (peak: 96.0M)
CPU: 7.623s
CGroup: /system.slice/gsd.service
└─ 21092 gvm: Waiting --osp-vt-updater/run/ospd/ospd.sock --listen-group=gvm
└─ 21118 gsd: 'background' --osp-vt-updater/run/ospd/ospd.sock --listen-group=gvm
└─ 21221 gsd: 'syncing' --osp-vt-updater/run/ospd/ospd.sock --listen-group=gvm
└─ 21122 gsd: 'syncing' --osp-vt-updater/run/ospd/ospd.sock --listen-group=gvm

Jul 11 04:13:18 Kali system[1]: Starting gvm.service - Greenbone Vulnerability Manager daemon (gvm)...
Jul 11 04:13:18 Kali system[1]: gsd.service: Can't open PID file '/run/gvm/gsd.pid' (yet) after start: No such file or directory.
Jul 11 04:13:18 Kali system[1]: Started gvm.service - Greenbone Vulnerability Manager daemon (gvm).

* ospd-opensvas.service - OSPD Wrapper for the OpenVAS Scanner (ospd-opensvas)
Loaded: loaded (/usr/lib/systemd/system/ospd-opensvas.service; disabled; preset: disabled)
Active: active (running) since Fri 2025-07-11 04:13:18 MAT; 7s ago
Invocation: 08e21435643738b1c4b3f773f8d1
Docs: man:ospd-opensvas(8)
Process: 21070 ExecStart=/usr/bin/ospd-opensvas --config /etc/gvm/ospd-opensvas.conf --log-config /etc/gvm/ospd-logging.conf (code=exited, status=0/SUCCESS)
Main PID: 21070 (ospd-opensvas)
Tasks: 5 (limit: 2200)
Memory: 63.3M (peak: 104M)
CPU: 4.044s
CGroup: /system.slice/ospd-opensvas.service
└─ 21070 /usr/bin/ospd-opensvas --config /etc/gvm/ospd-opensvas.conf --log-config /etc/gvm/ospd-logging.conf
└─ 21088 /usr/bin/ospd-opensvas --config /etc/gvm/ospd-opensvas.conf --log-config /etc/gvm/ospd-logging.conf

Jul 11 04:13:18 Kali system[1]: Starting ospd-opensvas.service - OSPD Wrapper for the OpenVAS Scanner (ospd-opensvas)...
Jul 11 04:13:18 Kali system[1]: Started ospd-opensvas.service - OSPD Wrapper for the OpenVAS Scanner (ospd-opensvas).

[+] Opening Web UI (https://127.0.0.1:9392) in: 5 ... 4 ... 3 ... 2 ... 1 ...

root@kali:~#
```

Image showing gvm-start and opening the web UI <http://127.0.0.1:9392>

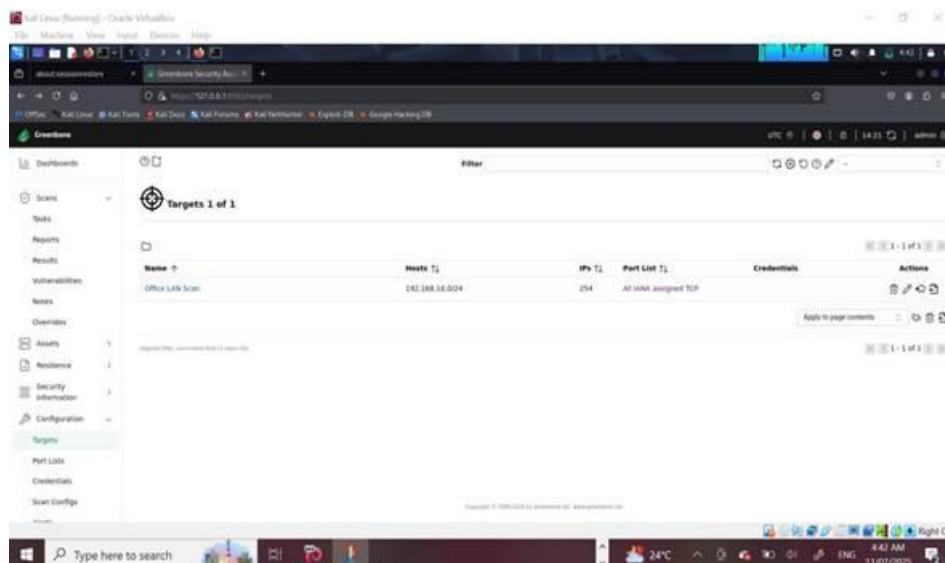


Image greenbone web showing the target 'Office LAN Scan'

Prepared by: Agbo D. C

Date: October 11, 2025

Tool Used: OpenVAS (GVM) V25.04.0